

신뢰 봉인 Trust Sealing 착수 지시

대표 결정 3건(P-LOCAL-5·보안·probe)을 전부 수용·확정하고, 상품화 로드맵 1단계 "신뢰 봉인"을 Code 작업 패키지로 발주합니다. R1 격리 · R2 저하 운전 · R3 API 계약을 증거로 봉인합니다.

GATE 0
로컬 기동



WP-2
신뢰 봉인
R1·R2·R3



EXIT
대표 승인



다음
U1~U4
가치 기능

이 지시서의 원칙

신규 기능은 아직 만들지 않는다.
먼저 "안 보인다·안 죽는다·감사 통과"를 증거로 봉인한다.

확정된 결정 3건 · 선행 게이트

§0 대표 결정 — 전부 수용 확정

decisions.yaml 추가

D-243 superuser 역할 — 분리·순차 회수 (무중단)

확정

즉시 회수 아님. GAION 운영자 전용 슈퍼 역할과 고객 테넌트 운영 역할을 분리 정의 → 고객 테넌트 계정에 "자기 테넌트 관리" 대체역할 먼저 부여 → 검증 후 superuser 역할 회차별 회수. 13개 실계정 무중단. Code는 로컬/스테이징 스크립트·시험까지만, 운영 반영은 대표 승인 후. → W0-13 차단 해제.

D-244 보안 즉시조치 — 대표/운영자 수행

확정

① 자격증명 anyang/Admin@123 즉시 회전 ② HTTPS + 접근 IP 제한 ③ 서버 결제계정 생존 확인. Code는 .env* 실값 무기입.키 form 검증·노출 0건 유지만. 운영 서버 접속은 Code 소관 아님.

D-245 probe_guardianx 복제본 삭제

확정

실사용자 9명 비번이 재설정된 로컬 복제본. 증거 파일(evidence/W0-14/*) 커밋·재현 확인 후 DROP. 운영 복제본 database_guardianx는 무변경 확인만, 삭제 대상 아님.

§1 Gate 0 — 로컬 100% 기동 (선행)

변함없음

GATE 0 격리 시험이 로컬에서 실제로 돌아야 한다

R1 증거는 지금까지 probe 복제본에서만 나왔다. 저장소 자체가 로컬에서 기동·시험되지 않으면 봉인을 검증할 수 없다. → RUNBOOK_로컬기동.md 실행: build 폴더 인벤토리 → dj-core 설치본 수색 → venv 이식 → import core.base 관문 → manage.py check → 프론트 기동 → 미검증 재고 1,217줄 검증.

⚠ 경로 A 성공 → Gate 0 통과, WP-2 착수. / 셋 다 없음 → 목록만 보고 STOP. Gate 0 미통과 상태에서 S2 코드 작업 착수 금지.

신뢰 봉인 — 작업 티켓

ENTRY 조건: Gate 0 통과 + 이 문서 붙여넣기(승인) + review/WP-2/ENTRY.md APPROVED 기입. 경로①·②는 독립이므로 각각 막는다.

R1 테넌트 격리 봉인

P0 · 입찰 자격

W0-14

뷰 레벨 테넌트 스코프 롤아웃 (경로① 유일 차단 수단, 실측 확정). 파일럿 1개 → 통합시험 2건 green 후 확대(466 일괄 부착 금지). superuser 역할이 남아도 뷰에서 스코프 강제, created_by IS NULL도 소유 테넌트로 귀속.

W2-2

superuser 역할 분리·대체역할 부여 (D-243, 로컬/스테이징만). (a)13계정 전수 목록화 (b)운영자/테넌트 역할 분리 정의 (c)대체역할 부여 (d)자기 테넌트만 보이는지 HTTP 시험 (e)회수 절차서 작성 — 운영 반영은 대표 승인.

W0-13

created_by 백필 (경로②). 파괴적 변경이므로 dry-run 리포트 먼저(D-209). 뷰 스코프와 독립 — 둘 다 해야 함.

R2 저하 운전

P0 · 운영 신뢰

W2-3

외부 의존 부분 실패 격리. 목록 API가 스트리밍 상태조회 실패 시 500 대신 스트리밍 필드만 "일시 불가"+200. 각 외부 의존(스트리밍·AI·저장소)에 타임아웃·폴백. 시험: 외부 의존 다운 모킹 → 목록·이력·통계 200 유지.

R3 API 계약 정합

P0 · 감사·연동

W2-4

상태코드·엔드포인트 정정. 권한거부를 HTTP 200 body → 403으로(클라 호환 영향조사 먼저). /api/token/pair 표준 복구 또는 문서를 실경로 /api/v1/auth/login로 정정. delete-session body 호출 수정. 계약테스트 추가.

✓ EXIT 조건 — 전부 충족 시 제출하고 멈춘다

1. 로컬 테넌트 격리 HTTP 시험 466/466 green (경로①·② 모두 차단 실측)

2. 대체역할 무중단 검증 완료 + superuser 회수 절차서 작성 (운영 반영은 대표 승인 대기)

3. 외부 의존 다운 시 핵심 기능 200 유지 시험 green

4. API 계약테스트 green + 연동 문서 갱신

5. 미검증 재고 1,217줄 검증 완료 · 시크릿 0건 · \$0.4 무변경 · 파괴적 변경 dry-run 첨부

불변 제약 · 승인 · 실행 순서

§3 불변 제약 (위반 시 hard_stop)

- ❌ 권한 우회 목록 추가 금지 (D-103) · 격리 시험 비활성·수정·스킵 금지 (D-105)
- ❌ dj-core·rj-core §0.4 금지구역 직접 수정 금지 (D-207) — 격리는 뷰/서비스 레이어에서만
- ❌ 파괴적 마이그레이션은 dry-run 리포트 먼저 (D-209) — created_by 백필 포함
- ❌ .env* 실값 무기입 (D-204) · 백업은 저장소 밖 암호화 (D-002)
- ❌ 운영 서버(115.21.49.115)·운영 DB 직접 접속/변경 금지 — 전부 로컬/스테이징에서

§4 대표 승인란

한 줄만 기입

Code가 §0 정서를 마친 뒤, 아래 파일 첫 줄에 기입하시면 WP-2가 착수됩니다.

```
review/WP-2/ENTRY.md
```

APPROVED: 2026-08-22 강희석

EXIT 승인은 로컬 466/466 green + 절차서 완성 후 재제출 시점에 별도로 하십니다(D-237). superuser 운영 반영과 보안 즉시조치(D-244)는 대표님/운영자가 직접, AI 세션 경유 없이 수행하십니다.

§5 실행 순서

- 1 §0 결정 3건 정서 (D-243·244·245 decisions.yaml 추가) — 커밋 1개
- 2 Gate 0 로컬 기동 (RUNBOOK 실행) → 경로 A/B 판정 보고. **셋 다 없으면 STOP.**
- 3 Gate 0 통과 시 WP-2 착수 — R1(W0-14 → W2-2 → W0-13) → R2(W2-3) → R3(W2-4)
- 4 EXIT 5조건 충족 시 제출하고 멈춘다 — 신규 가치 기능 착수 금지
- 5 대표 EXIT 승인 후 U1~U4 가치 기능 단계로 이행

요약 — 이번 지시의 성공 기준은 코드 줄 수가 아니라 "나의 지자체가 안 보인다 466/466 · 하나 죽어도 안 멈춘다 · 감사에 통과한다"를 실측 증거로 만드는 것입니다. 그 증거가 곧 다음 상용 계약의 자산입니다.